

Securing Open Sound Control (OSC) over UDP: A Lightweight HMAC-Based Authentication Scheme for Embedded Systems

Paul V. Miller

April 19, 2026

1 Introduction

This project presents a lightweight authentication layer for transmitting OSC (Open Sound Control) packets over UDP, using HMAC and sequence-based replay protection. The approach is designed for resource-constrained embedded controllers that operate in live performance or real-time musical applications.

2 Background

2.1 OSC

OSC (Open Sound Control) is widely used in computer music and interactive systems for sending live performance data. Very frequently the data is some musical control information (such as frequency or amplitude) that is produced by a human interface. Many OSC software controllers are available online such as TouchOSC or Protokol. Users can install these on a so-called “smart”-phone or tablet. These applications frequently allow the user to design a custom interface that can include virtual buttons, sliders, knobs, or other kinds of control UIs that produce data for a synthesizer or some other kind of application. A typical setup is shown below.



Figure 1: TouchOSC with custom interface (image from TouchOSC’s web site)

It is also possible to build one’s own physical controllers out of hardware components such as sliders, buttons, potentiometers, or even more sophisticated sensors (e.g. LSM9DS1 or BNO055). A small inexpensive microcontroller such as a Raspberry Pi Pico W can then run code that formats the data into an OSC message and send it through a wired or wireless connection.

2.2 OSC Encoding: The Details

The OSC protocol uses a hierarchical address space in which each message includes an address pattern that identifies its destination on the receiving end, within a tree-like namespace (somewhat like a hierarchical filesystem structure).¹ The idea behind OSC was to improve upon the 1983 MIDI standard which, though useful in many cases, is limited to 7-bit values 0-127.² OSC is designed to work well with patching environments such as Max/MSP and Pd, because its message tree structures can be very easily separated using the [route] object common in most patchers.³

An OSC message can mix data types such as integer and float:

```
/controller/move/ 60 0.75 "legato"
```

The command above sends a message to the address `/controller/move/` with three arguments: 60, 0.75, and “legato”.⁴ This is the format that most naive users see. But OSC messages must also include a positional tag that stipulates the data types being used in the correct order. For the message above, we need:

```
,ifs
```

This particular positional tag stipulates that “the first datum is an integer, the second is a float and the third is a string”. The type tag always begins with a comma.⁵ To send the control message above through UDP, we must do the following:

1. First encode the address string in hexadecimal `“/controller/move/”`, which is null-terminated and padded to a multiple of 4 bytes (in this particular case we have 16 bytes for the string, plus 1 for the null termination and then 3 more for padding, resulting in a final payload of 20 bytes);
2. Next, encode the type tag string `“,ifs”`, which must begin with a comma. It is also null-terminated and padded to a multiple of 4 bytes (in this specific case we have a four-byte tag, which means we need 1 more byte for the null termination and then 3 more bytes for padding, resulting in 8 bytes);
3. Finally we can send the arguments:
 - (a) Integers are 32-bit signed, and need to be big-endian (network byte order);
 - (b) Floats are 32-bit IEEE 754 standard floating-point, and are also big-endian;
 - (c) Strings are standard ASCII and must be null-terminated, and padded to 4 bytes, so “legato” in OSC is 8 bytes.

These standards decrease the potential ambiguity in sending OSC messages.

2.3 Threat Model: Background

Sending OSC messages usually happens over UDP, because transmission needs to be quick and low-latency. UDP does not normally engage in TCP’s “three way handshake” (SYN – SYN-ACK – ACK) nor is there a sequence number involved, nor does it retransmit lost packets. The logic behind using UDP is that in live performance, it is usually better just to drop a lost packet than to wait for it.

¹Wright and Freed 2002

²The most significant bit in MIDI (the 8th bit) distinguishes status bytes from data bytes, allowing the system to differentiate between “starting a new message” (status byte) and “this byte is a continuation of the current message” (data). The designers of MIDI understood that there would probably only be 127 discrete values for pitch and volume, so they left it at that. This corresponds (very) roughly to the number of keys on the modern Steinway piano (88). The MIDI standard cannot natively send other kinds of performance data such as floating-point numbers or strings.

³While OSC has been widely adopted since its inception, it is not without critics. See Supper 2012

⁴Conceptually this is something like sending parameters to a function: `move(60, 0.75, “legato”)`.

⁵There are several OSC type tags in the protocol specs. To summarize:

numeric: i, f, h, d (integer, float, 8-byte int, 8-byte float)

text/binary: s, b: string, blob (a binary blob can be of arbitrary length, and can transmit audio chunks, etc.)

special: T, F, N, I: these do not have any corresponding data bytes – the type tag alone carries information (True, False, Null, Infinity)

structural: t, m, r (timetag, MIDI, color in a 4-byte RGBA format!)

However, because UDP removes several mechanisms for authentication and state, it makes some attacks much easier. While it is possible to “spoof” TCP packets and even to inject data under some circumstances, UDP doesn’t have any connection state, sequence tracking or verification. So the receiver doesn’t really know where a packet came from. This makes spoofing and injection attacks much easier to perpetrate.

2.4 Threat Assessment

In a typical performance or installation that utilizes OSC over WiFi systems, an attacker has to be on the same network as the victim. For open networks, gaining this kind of access is trivial. For closed networks, it is not easy to crack a router’s WiFi password (particularly if it is encoded using WPA2 or WPA3). However, musicians and artists are frequently unaware of the security vulnerabilities that routers expose. For example, routers are often shared assets that pass fluidly from person to person, with several individuals aware of the password. Router passwords are frequently shared in a cooperative environment. The sticker on the router advertising the credentials may not be removed, boldly advertising the password to any “curious” passerby who snaps a photo of the tech setup. Consequently, an attack would most likely come from an insider wanting to disrupt a performance.

If the router password is known, an attacker would still need to know the port number through which OSC data was being transmitted. In TCP and UDP, port numbers are 16 bits long. Certain ports are more frequently used for OSC transmission because of their prevalence in online tutorials: for example, most Max/MSP tutorials use ports 7000, 8000 or 9000.⁶ Although port scanning is easy for TCP services discovery, it is more difficult on UDP. Although UDP services may not respond to invalid probes, it remains feasible to scan all 65,536 ports in a short period of time; a single successful OSC injection would tell the attacker that they found the right port.

Distinct from but related to message injection, *flooding* is a second problem that frequently occurs even when legitimately sending OSC control codes. Too many messages arriving at the same time can overload the ability to process them all, causing sequencing and timing issues in audio applications. Message flooding could occur if an attacker captured encrypted OSC control codes and replayed them, overwhelming the victim.

There are no native security features for sending OSC messages over UDP apart from the general features of WiFi routers. The protocol operates entirely on a trust model. Most artists using these systems are not trained in security measures. I have personally witnessed radically insecure setups at electronic music performances.

Breach of this trust model can easily result in a catastrophic attack. Injecting OSC messages can grind a performance completely to a halt. If the unfortunate performers were to restart, the security issues would be unresolved and the attack could resume unabated. The impact on a live performance could be enormous, potentially resulting in disruption, significant reputational harm, and audience dissatisfaction.

In summary: a *very realistic threat* could come from an attacker who already has another device on the WiFi router, and knows the port. A *moderately realistic threat* could come from someone who is on the WiFi router but brute-forces the port number. A *less realistic threat* would be an external attacker who cracks WiFi, then scans ports.

3 Materials and Methods

3.1 Materials

In this project I used four Raspberry Pi Pico W boards and standard, low-cost electronics components such as breadboards, jumper cables (Dupont style), 6x6mm buttons, a 10k Ω potentiometer, and simple LEDs for status indications. A dedicated WiFi router was necessary, since DuqNet does not allow ad-hoc UDP. I built two pairs of victim/attacker setups, to demonstrate unsecured and secured models. The code was written in MicroPython, a special lightweight version of Python that runs on embedded systems. The OSC messages were received on a Mac M1 or M4 running Max 9.x. The four builds are shown below:

⁶Another widely-used synthesis environment – SuperCollider – simply defaults to port 57120.

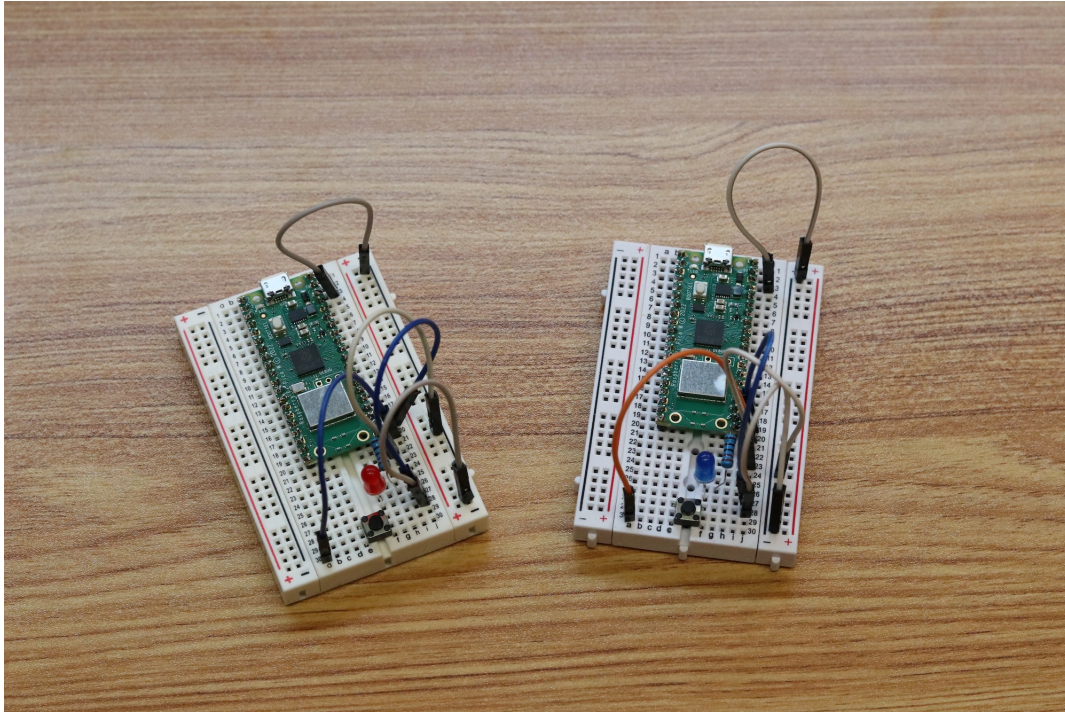


Figure 2: Unsecured Raspberry Pi Pico W builds: attacker (left, with red LED) and victim (right, with blue LED)

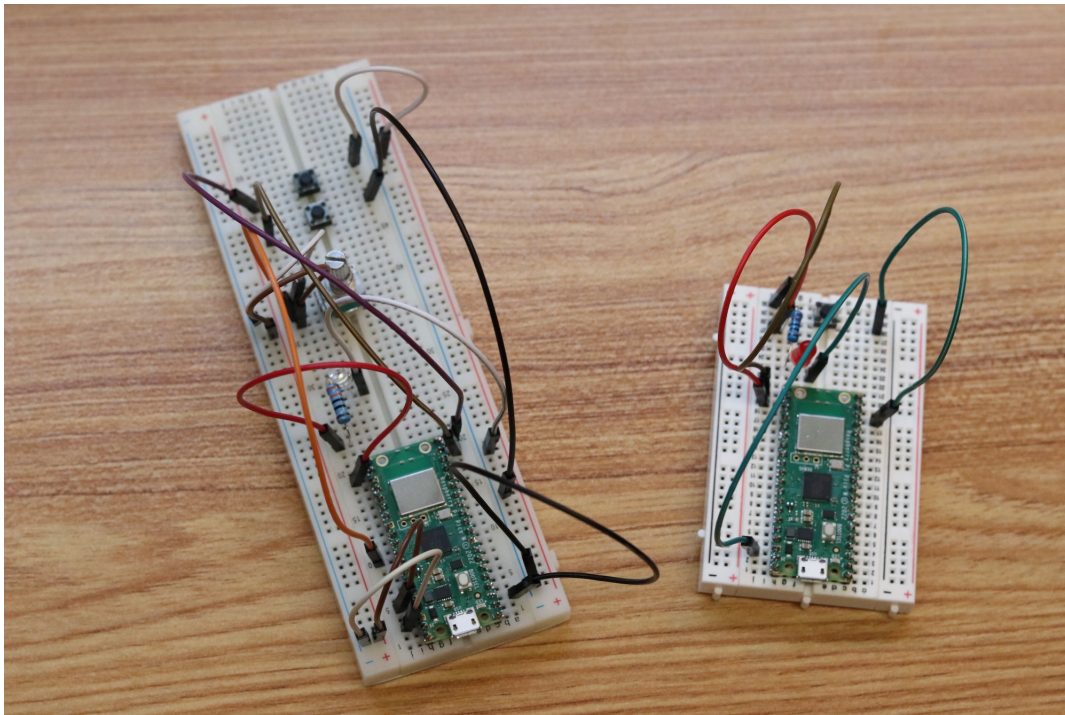


Figure 3: Secured system (left, with white LED, potentiometer and two buttons,) and attacker (right, with red LED and button).

3.2 Methods

3.2.1 Packet Structure

The packet consisted of a header, payload and HMAC-SHA256 tag. Specifically, packets were structured in the following manner:

1. Header: 12 bytes, >BIIH formatted string for `struct.pack()` and `struct.unpack()` in Python:
 - (a) > = indicates big-endian byte order (for network transmission);
 - (b) B = 1 byte = version number;
 - (c) B = 1 byte = flags;
 - (d) I = 4 bytes = device id;
 - (e) I = 4 bytes = sequence number;
 - (f) H = 2 bytes = payload length.
2. OSC Payload = 28 bytes
 - (a) The shortest control string I was transmitting is `/controller/pot1`. This is 16 characters. But OSC has to be null-terminated, so this becomes 17 bytes. I padded this to 20 bytes.
 - (b) OSC's type tag string, e.g. `"f"`. This is 2 characters plus a null terminator, so 3 bytes. Padded to 4 bytes.
 - (c) The float argument in OSC is a 32-bit float, which adds 4 bytes.
 - (d) Altogether this sums to 28 bytes for the entire OSC payload.
 - (e) Now let's examine what happens if we transmit the longest control string: `/controller/button1`. This sums to 19 characters, plus a null terminator = 20. This is already a multiple of 4, so it doesn't need padding.
 - (f) The type tag string for this is `"i"`, which is 2 characters plus the obligatory null terminator, which (when padded) again yields 4 bytes.
 - (g) OSC integers are 32 bits, so this is 4 bytes.
 - (h) The total payload size in this case is also 28 bytes.
 - (i) If I were to have a control string such as `/controller/button10`, I would have to increase the payload length.
3. HMAC-SHA256 tag = 16 bytes
 - (a) A full SHA-256 hash is 32 bytes, but I truncated it to 16 (which still gives 2^{128} possible tags, which is probably secure enough);
 - (b) The hash was truncated to save overhead and improve latency, which is important in this project;
 - (c) The keyed hash was computed over the header AND the payload.

Since $12 + 28 + 16 = 56$, the total size of each packet is always 56 bytes.

3.2.2 Authentication Mechanism

As mentioned above, this is HMAC-SHA256 over the header and the OSC payload, truncated to 16 bytes. The key is NOT transmitted and is shared "out of band". Securely sharing the key is therefore the responsibility of the people implementing the system.

3.2.3 Replay Protection

This was implemented with monotonically increasing sequence numbers. The receiver gateway rejects duplicates or out-of-order packets (depending on policy).

3.2.4 Implementation Details

On the secured Pico, we need the following files:

- **controller.py** (later moved to **main.py**):⁷ this is the main script that connects to WiFi, reads data from the potentiometer and the two buttons, and calls `send_secure_osc()`, which in turn calls `osc_pack()` from `osc_min.py` and `build_packet()` from `secure_packet.py`. It reports results to the REPL.
- **credentials.py**: This is a short script that contains the global constants `WIFI_SSID`, `WIFI_PASS`, `DEST_IP`, `DEST_PORT`, `HMAC_KEY`, a `DEVICE_ID`, as well as GPIO assignments for the Pico W;
- **osc_min.py**: this script builds the secure OSC packet;
- **secure_packet.py**: this builds the packet's header, calculates the HMAC-SHA256 hash, and truncates it to 16 bytes.

On the attacker Pico, we need:

- **attackx.py**: this is the script that perpetrates the attack. There are three of these: **attack1.py**, **attack2.py** and **attack3.py**;
- **credentials.py**: this is where forged credentials live, as well as all the other global constants such as `WIFI_SSID`, etc.;
- **osc_min.py**: this is exactly the same as the secured Pico, and builds OSC packets.

The Picos send their packets to port 9000, which is what **gateway.py** listens for on the receiving end. After the packets are received from the network socket and processed, the gateway sends diagnostic messages (logs) to `stdio`. It then forwards legitimate OSC to localhost on port 8000 for Max/MSP to listen to.

4 Results

I made a video demonstrating the unsecured operation, as well as three attacks on the secure system. It can be viewed on YouTube at <https://youtu.be/PUTnueV0Z5I>.

4.1 Basic Attack Demonstration

As proof-of-concept, I simulated a trivial attack using two Raspberry Pi Pico Ws without any security mechanism whatsoever. The victim simply sent OSC messages containing MIDI notes that produced a three-octave C Major arpeggio on the receiving end through a simple Max/MSP patch. The attacker sent random MIDI values on the same port as the victim, dramatically disrupting the arpeggio. The MIDI notes were shown on a standard musical staff as they were received and processed. The following screenshot shows the network setup on the router, and the results of the attack right at the moment it begins, on the musical staff in Max/MSP:

⁷This discrepancy is due to the fact that MicroPython will automatically execute any file named “main.py” when the Pico powers up. It is therefore quite advantageous to develop and test `main.py` using some alternative filename to prevent the system from accidentally executing it on powerup. When deployed, the file is copied to `main.py`.


```

From 192.168.1.5:62692 length=56
010000000001000000b4001c2f636f6e74726f6c6c65722f706f743100000002c6600003e3d08bdfca98059aafb511543666424321fc95e

From 192.168.1.5:62692 length=56
010000000001000000b4001c2f636f6e74726f6c6c65722f706f743100000002c6600003e61cce2bae795b8f168e4285def1c826163eeba

From 192.168.1.5:62692 length=56
010000000001000000b4001c2f636f6e74726f6c6c65722f706f743100000002c6600003e770cf72da3fede65aeb01e8ebb97cec433bfdf

From 192.168.1.5:62692 length=56
010000000001000000c0001c2f636f6e74726f6c6c65722f706f743100000002c6600003e87288720b6ea067892e33b3009da811c10cf9a

From 192.168.1.5:62692 length=56
010000000001000000c1001c2f636f6e74726f6c6c65722f706f743100000002c6600003e924892af6260ef6fed585be2471ef9f81b73f0

From 192.168.1.5:62692 length=56
010000000001000000c2001c2f636f6e74726f6c6c65722f706f743100000002c6600003ea60aa62df5f094921b6228bb999f98232ee499

From 192.168.1.5:62692 length=56
010000000001000000c3001c2f636f6e74726f6c6c65722f706f743100000002c6600003e9b489b298bff8090d720167576ef81f2d3105d

From 192.168.1.5:62692 length=56
010000000001000000c4001c2f636f6e74726f6c6c65722f627574746f6e31002c690000000000014ac27aedbf58cbdec6d3c5bdc9905a17

From 192.168.1.5:62692 length=56
010000000001000000c5001c2f636f6e74726f6c6c65722f627574746f6e31002c69000000000000790bf909ec0a3e7952ebc5be5a6fcab6

From 192.168.1.5:62692 length=56
010000000001000000c6001c2f636f6e74726f6c6c65722f627574746f6e32002c690000000000001b75a56c4654b3b10e156218e990519b6

From 192.168.1.5:62692 length=56
010000000001000000c7001c2f636f6e74726f6c6c65722f627574746f6e32002c69000000000000728e809885d3aabce7513248aee120c8

```

To verify packets of potentiometer and button information were being correctly received by Max, I built a patch that mapped potentiometer value to frequency of a generic sawtooth oscillator, and each of the two buttons to a simple amplitude envelope of varying duration. The Max patch conveniently included a message that spawned a shell, executing a trivial shell script that in turn started the `gateway.py` program. A corresponding Max message killed `gateway.py`.

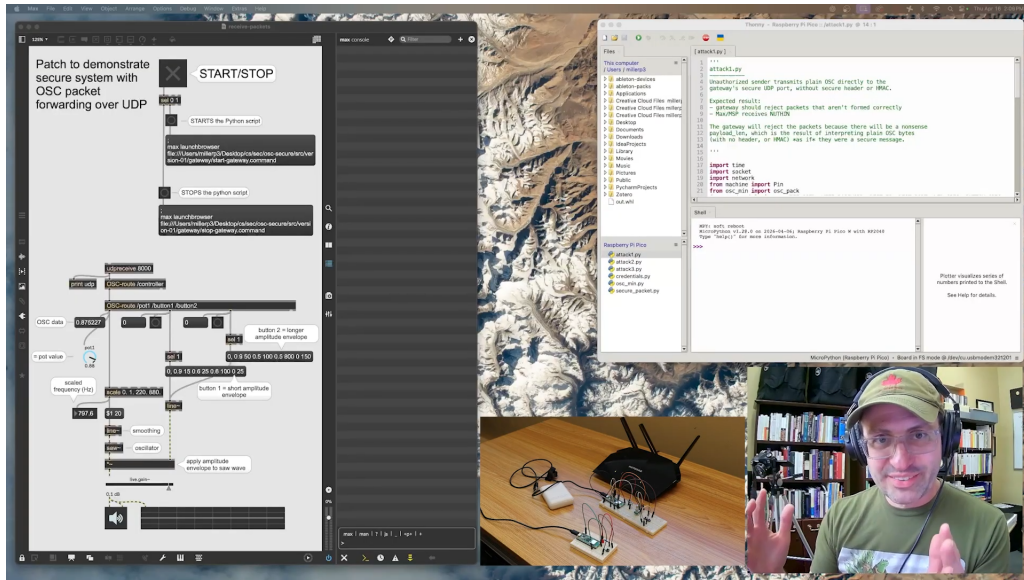


Figure 5: Secured OSC: screenshot from YouTube video

4.2.2 Attack 1: Sending plain OSC without the proper header

In the first attack, I attempted to send plain OSC packets through the secure system without a header or HMAC hash. The gateway interprets the first 12 bytes as version, flags, device_id, seq and payload_len, so it translated these plain bytes as a “garbage” payload length – which in this case worked out to 29,259:


```

DROP replay: device=1 seq=26 last_seq=124
DROP replay: device=1 seq=26 last_seq=124
DROP replay: device=1 seq=26 last_seq=124
DROP replay: device=1 seq=26 last_seq=124
DROP replay: device=1 seq=26 last_seq=124
ACCEPT device=1 seq=125 payload_len=28 total=56 stats: ok=10 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=126 payload_len=28 total=56 stats: ok=11 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=127 payload_len=28 total=56 stats: ok=12 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=128 payload_len=28 total=56 stats: ok=13 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=129 payload_len=28 total=56 stats: ok=14 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=130 payload_len=28 total=56 stats: ok=15 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=131 payload_len=28 total=56 stats: ok=16 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=132 payload_len=28 total=56 stats: ok=17 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=133 payload_len=28 total=56 stats: ok=18 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=134 payload_len=28 total=56 stats: ok=19 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=135 payload_len=28 total=56 stats: ok=20 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=136 payload_len=28 total=56 stats: ok=21 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=137 payload_len=28 total=56 stats: ok=22 hmac=0 replay=6 len=0 bad_version_count=0
ACCEPT device=1 seq=138 payload_len=28 total=56 stats: ok=23 hmac=0 replay=6 len=0 bad_version_count=0

```

4.3 Performance

I did an analysis of latency by making a parallel branch of the code. Latency was measured in two ways: first as a round-trip timing (RTT), and second as gateway processing overhead on the Mac (receiving end). The round-trip method was chosen because it is not possible to synchronize clocks on the Raspberry Pi Pico W and the Mac.

The results of analyzing 30 packets reveal much interesting information. I found that latency was almost the same for plain OSC and secure OSC. Plain RTT averaged 211.1 - 212.0ms for most samples, with one outlier at 310.8ms. Secure RTT also averaged 211.2 - 212.2ms for most samples, with one larger outlier at 512.8ms. This data allows me to conclude that the practical end-to-end RTT in the project is dominated by something other than HMAC verification – most likely, the latency in WiFi variability.

A better indication of the actual cost of the security layer was gateway-side timing. Gateway-side timing is the time taken to parse, verify and forward secure OSC packets to the loopback after the Python script receives them from the OS. This includes the time it takes to:

1. extract version, flags, device_id, seq, payload_len;
2. check the length of the data to make sure it conforms to expected_len;
3. check the recovered HMAC tag to make sure it conforms to the expected tag (using `hmac.compare_digest()`...)
4. enforce replay protection;
5. and finally, forward the verified OSC string to the loopback with `forward_sock.sendto(payload, ('127.0.0.1', 8000))`.

Notably, gateway-side timing explicitly *does not* include the network transit time it takes the packet to move from the Pico to the Mac, or socket receive blocking time. The timer starts only *after* we receive a packet from the OS socket:

```

recv_sock.bind(('0.0.0.0', 9000))
data, addr = recv_sock.recvfrom(...)

```

In the plain gateway-side timing, processing time averaged about $160.8\mu s$ over 30 packets, with a range of $97.2 - 210.0\mu s$, while in the secure gateway-side timing, processing averaged $218.6\mu s$ with a range of $146.9 - 366.5\mu s$. So we can conclude that **the secure version adds about $58\mu s$ on average** to the gateway overhead compared to the plain OSC. This is negligible in the parameters of this project. The results are summarized in the table below.

Measurement	Range	Mean	Outlier(s)
Plain OSC: Round-Trip Time	211.1 – 212.0 ms	211.5 ms	310.8 ms
Secure OSC: Round-Trip Time	211.2 – 212.2 ms	211.8 ms	512.8 ms
Plain OSC: Gateway Processing Time	97.2 – 210.0 μs	168.8 μs	none
Secure OSC: Gateway Processing Time	146.9 – 366.5 μs	218.6 μs	366.5 μs

Table 1: Latency Times as Measured over 30 Packets

5 Discussion

This lightweight system for authenticating OSC over UDP worked well, added only an insignificant amount of latency, and survived three simulated attacks. When a user installs the Python code on the transmitting and receiving ends, the system’s security increases dramatically.

The most significant weakness in the current system is that a longer OSC payload is not supported, because the OSC string is limited to 28 bytes. A design goal for a potential version 2.0 would be to make the OSC payload variable. It is the user who should determine the size of the OSC payload, not the system. A future version would respond to whatever length OSC string the user sent into it (within reason).

6 Conclusion

My system provides *integrity* through HMAC, *authenticity* through a shared key, but lacks confidentiality as there is no encryption. This was a purposeful design choice, as I did not want to increase latency by introducing an encryption/decryption layer. However, noting that the cost of the current system is so low, adding encryption might be worth pursuing in the future.

Although an attack on transmitting OSC information over UDP is unlikely, it is potentially catastrophic in a sensitive performance environment. My system provides an added layer of security to defend against three possible attack vectors, dramatically increasing the overall system resilience.

References

- Bishop, Matthew (2018). *Computer Security: Art and Science*. 2nd. Boston: Addison-Wesley.
- Krawczyk, Hugo, Mihir Bellare, and Ran Canetti (1997). *HMAC: Keyed-Hashing for Message Authentication*. Tech. rep. RFC 2104. IBM and UCSD; RFC 2104. URL: <https://www.rfc-editor.org/rfc/rfc2104>.
- Postel, Jon (1980). *User Datagram Protocol*. Tech. rep. RFC 768. RFC Editor. URL: <https://www.rfc-editor.org/rfc/rfc768>.
- Supper, Ben (Oct. 2012). *We hate MIDI. Welove MIDI*. Internet. URL: <https://focusritedevelopmentteam.wordpress.com/2012/10/24/we-hate-midi-we-love-midi/>.
- Wright, Matthew and Adrian Freed (2002). “Open Sound Control: A New Protocol for Communicating with Sound Synthesizers.” In: *Proceedings of the International Computer Music Conference (ICMC)*.